# Case 03 — Web Shell Investigation

## 1. Alert Summary

| Field | Value |
|---|---|
| Case | `Case-03-Web-Shell` |
| Target Host | `Dev-QA-Server` |
| Source/Attacker IP | `171.251.232.40` |
| Observed Web Request | `GET /wp-login.php HTTP/1.0` |
| User-Agent | `Mozilla/5.0 (Hydra)` |

The investigation identified suspicious automated web activity originating from `171.251.232.40`. The request targeted the WordPress login endpoint `/wp-login.php` and used a Hydra user-agent.

Additional endpoint telemetry showed PowerShell executing a command that searched the entire `C:\` drive for files containing `password`, `creds`, or `confidentials`.

## 2. Investigation Objective

The objectives were to:

- Identify the source/attacker IP.
- Identify the suspicious HTTP request.
- Identify the affected host.
- Investigate commands executed on the host.
- Build a timeline of the activity.
- Determine whether the activity represents malicious behavior.

## 3. Tools Used

- Splunk
- Sysmon
- Windows Event Logs
- TryHackMe
- MITRE ATT&CK

## 4. Source IP Analysis

The source IP identified during the investigation was:

```
171.251.232.40
```

This IP was associated with the suspicious web activity.

## 5. Suspicious Web Request

The following HTTP request was identified:

```
GET /wp-login.php HTTP/1.0
```

The associated User-Agent was:

```
Mozilla/5.0 (Hydra)
```

The request targeted the WordPress login endpoint.

The use of Hydra indicates automated authentication-related activity.

## 6. Host Analysis

The Splunk search returned:

```
Host: ce-splunk | Count: 340
```

However, `ce-splunk` is treated as the Splunk/logging host and is **not confirmed as the compromised web server** based on the available evidence.

Endpoint telemetry separately identified:

```
ComputerName: Dev-QA-Server
```

Therefore, `Dev-QA-Server` is the confirmed Windows endpoint associated with the PowerShell activity.

## 7. PowerShell Activity

Sysmon Event ID 1 recorded the creation of a PowerShell process.

**Process:**

```
C:\Windows\SysWOW64\WindowsPowerShell\v1.0\powershell.exe
```

**Process ID:**

```
3368
```

**Parent Process:**

```
C:\Windows\SysWOW64\cmd.exe
```

**Parent Process ID:**

```
5684
```

**User:**

```
NT AUTHORITY\SYSTEM
```

### *Command Executed*

```
powershell.exe -Command "Get-ChildItem -Path 'C:\' -Recurse -File | Where-Object {
$_.Name -match 'password|creds|confidentials' }"
```

The command recursively searched the `C:\` drive for files with names containing:

- `password`
- `creds`
- `confidentials`

This is consistent with credential and sensitive-data discovery activity.

## 8. Timeline

| Time | Activity |
|---|---|
| 12/07/2024 04:01:06 PM | Sysmon recorded PowerShell process creation |
| 12/07/2024 04:01:06 PM | PowerShell executed a recursive search for password/credential/confidential files |
| Observed web activity | Source IP `171.251.232.40` accessed `/wp-login.php` |
| Observed web activity | User-Agent identified as `Mozilla/5.0 (Hydra)` |

## 9. Indicators of Compromise

| Type | Indicator | Description |
|---|---|---|
| IP | `171.251.232.40` | Source IP associated with suspicious web activity |
| URL | `/wp-login.php` | WordPress login endpoint accessed by the source |
| User-Agent | `Mozilla/5.0 (Hydra)` | User-Agent associated with automated authentication activity |
| Host | `Dev-QA-Server` | Windows endpoint associated with the PowerShell activity |
| Process | `powershell.exe` | PowerShell process used to execute the discovery command |

| Type | Indicator | Description |
|---|---|---|
| Command | `Get-ChildItem ... password\|creds\|confidentials` | Recursive search for potentially sensitive files |

## 10. MITRE ATT&CK; Mapping

### *T1110 — Brute Force*

The Hydra User-Agent associated with the WordPress login endpoint is consistent with automated password-guessing activity.

### *T1083 — File and Directory Discovery*

The PowerShell command recursively searched the filesystem for files matching sensitive keywords.

### *T1081 — Credentials in Files*

The search specifically targeted filenames containing `password` and `creds`, indicating an attempt to locate credentials stored in files.

## 11. Analyst Assessment

### Verdict: SUSPICIOUS / TRUE POSITIVE FOR MALICIOUS ACTIVITY

The evidence confirms suspicious automated web authentication activity from `171.251.232.40` and suspicious PowerShell-based file discovery on `Dev-QA-Server`.

However, the available evidence does **not independently prove that** `/wp-login.php` **was a web shell**. Therefore, the investigation does not claim `/wp-login.php` itself was a web shell.

Further investigation would be required to establish a direct connection between the web activity and the PowerShell execution.

## 12. Recommended Response

1. Investigate the source IP `171.251.232.40`.
2. Review WordPress authentication logs for successful and failed login attempts.
3. Check whether a WordPress account was compromised.
4. Review WordPress plugins, themes, and uploaded files for malicious scripts.
5. Investigate the PowerShell process and its parent process.
6. Search for additional commands executed by the same user/process.
7. Review files matching `password`, `creds`, and `confidentials`.
8. Reset potentially compromised credentials.
9. Review the endpoint for persistence or lateral-movement activity.

10 Continue monitoring the affected environment.